

USDT0 · SECURITY REVIEW

Stellar Contracts Review.

A security review of the USDT0 Stellar contracts.

CLIENT	PROJECT	REVIEW FIRM	REVIEW WINDOW	FINAL REPORT
Everdawn Labs	USDT0	Guardian	August 7 - August 11, 2026	August 19, 2026

§ 00

Contents.

13 pages - overview, confidence ranking, scope, 4 findings, disclaimer, and about Guardian.

§ 01	Overview	p. 03
§ 02	Confidence Ranking	p. 04
§ 03	Scope & Classifications	p. 05
	Files in Scope	p. 06
§ 04	Findings	p. 07
	Round 1 – Main Review · 4 findings	p. 8–11
§ 05	Disclaimer	p. 12
§ 06	About Guardian	p. 13

§ 01

Overview.

Guardian reviewed the USDT0 Stellar contracts from August 7 through August 11, 2026. The review covered the omnichain fungible token and Stellar Asset Contract manager components and recorded four Informational findings. All four remain Pending in the supplied export.

REVIEW FIRM	Guardian	REPOSITORY	Everdawn-Labs/usdt0-ofc-contracts
CLIENT	Everdawn Labs	MAIN REVIEW COMMIT	ef3db2a637a43f33dc17950afe4873d7c830c793
PROJECT	USDT0	SCOPE	16 Rust files · 594 source lines
REVIEW WINDOW	August 7 - August 11, 2026	REMEDIATION REVIEW	Pending
FINAL REPORT	August 19, 2026		

1.1 Confidence Ranking

5 / 5

Very High Confidence

The review covered all sixteen files and 594 source lines identified in the supplied scope. No Critical, High, Medium, or Low findings were recorded, and the four Informational findings are clearly documented. The remediation review remains Pending.

1 V. LOW	2 LOW	3 MED	4 HIGH	5 V. HIGH
-------------	----------	----------	-----------	--------------

1.2 Findings at a Glance

SEVERITY	TOTAL	PENDING	IN PROG	DECLINED	ACK	PARTIAL	RESOLVED
 Critical	0	0	0	0	0	0	0
 High	0	0	0	0	0	0	0
 Medium	0	0	0	0	0	0	0
 Low	0	0	0	0	0	0	0
 Info	4	4	0	0	0	0	0

§ 02

Confidence Ranking.

Guardian assigns a project-level confidence score using the scale below. The ranking combines finding severity, remediation outcome, and the reviewer's assessment of latent risk.

CONFIDENCE RANKING	DEFINITION AND RECOMMENDATION	RISK PROFILE
5 Very High Confidence ASSIGNED	Codebase is mature, clean, and secure. No High or Critical vulnerabilities were found. Follows modern best practices with high test coverage and thoughtful design. Recommendation: Code is highly secure at time of audit. Low risk of latent critical issues.	0 High/Critical findings and few Low/Medium severity findings.
4 High Confidence	Code is clean, well-structured, and adheres to best practices. Only 1 Significant issue was uncovered per week. Design patterns are sound, and test coverage is strong. Recommendation: Suitable for deployment after remediations; consider periodic review with changes.	0-1 High/Critical findings per engagement week and little to no Medium severity issues. Varied Low severity findings.
3 Moderate Confidence	Medium-severity and occasional High-severity issues found. Code is functional, but there are concerning areas such as weak modularity or risky patterns. No critical design flaws were identified, though some patterns could lead to edge-case issues. Recommendation: Address issues thoroughly and consider a targeted follow-up audit depending on code changes.	1-2 High/Critical findings per engagement week.
2 Low Confidence	Code shows frequent emergence of Critical/High vulnerabilities. Audit revealed recurring anti-patterns, weak test coverage, or unclear logic. These characteristics suggest a high likelihood of latent issues. Recommendation: Post-audit development and a second audit cycle are strongly advised.	2-4 High/Critical findings per engagement week, or additional unresolved High/Critical findings uncovered in remediation review.
1 Very Low Confidence	Code has systemic issues. Multiple High/Critical findings (≥ 5/week), poor security posture, and design flaws that introduce compounding risks. Safety cannot be assured. Recommendation: Halt deployment and seek a comprehensive re-audit after substantial refactoring.	≥ 5 High/Critical findings and overall systemic flaws.

§ 03

Scope & Classifications.

The scope comprised sixteen Rust files and 594 source lines across the omnichain fungible token and Stellar Asset Contract manager components. Repository paths below are reproduced exactly.

3.1 Severity Matrix

	IMP · HIGH	IMP · MEDIUM	IMP · LOW	IMPACT · HIGH	Significant loss of assets, harm to a group of users, or core protocol functionality is disrupted.
LIK · HIGH	Critical	High	Medium	IMPACT · MEDIUM	Small amount of funds can be lost, or ancillary functionality is affected. Users may experience reduced or delayed receipt.
LIK · MED	High	Medium	Low	IMPACT · LOW	Unexpected behavior in some functionality that is notable but does not meet the criteria for higher severity.
LIK · LOW	Medium	Low	Low	LIKELIHOOD · HIGH	Possible with reasonable assumptions that mimic on-chain conditions; cost is low compared to amount gained.
				LIKELIHOOD · MEDIUM	Possible only in uncommon cases or requires a large amount of capital relative to disruption caused.
				LIKELIHOOD · LOW	Unlikely to ever occur in production.

§ 03

Scope.

Files in scope, grouped by exact repository path. Source-line counts are physical source lines.

Everdawn-Labs/usdt0-oft-contracts

16 FILES · 594 SOURCE LINES

stellar-contracts/oft/src/	
oft.rs	111
lib.rs	18
stellar-contracts/oft/src/extensions/	
rate_limiter.rs	152
oft_fee.rs	136
pausable.rs	47
mod.rs	3
stellar-contracts/oft/src/oft_types/	
mint_burn.rs	19
lock_unlock.rs	18
mod.rs	9
stellar-contracts/oft/src/interfaces/	
mintable.rs	5
mod.rs	2
stellar-contracts/sac-manager/src/	
sac_manager.rs	44
lib.rs	12
storage.rs	7
stellar-contracts/sac-manager/src/interfaces/	
sac_admin_wrapper.rs	9
mod.rs	2

§ 04

Findings.

Four Informational findings are included from the main review. All four remain Pending in the supplied export.

ID	TITLE	CATEGORY	SEVERITY	STATUS	PAGE
ROUND 1 - MAIN REVIEW					
I-01	Stellar Trustline Gaps Block OFT Delivery	Documentation	INFO	PENDING	p. 8
I-02	Quoted Maximum Ignores Dust Rounding	Rounding	INFO	PENDING	p. 9
I-03	Unsafe Single-Step SAC Admin Transfer	Best Practices	INFO	PENDING	p. 10
I-04	Stellar Pause Leaves Inbound Transfers Pending	Documentation	INFO	PENDING	p. 11

Stellar Trustline Gaps Block OFT Delivery.

CATEGORY Documentation LOCATION Stellar trustline requirements

DESCRIPTION

The EVM OFT accepts a 32-byte destination but cannot determine whether the corresponding Stellar recipient can hold the Stellar asset. After tokens are burned on EVM, the Stellar OFT resolves the payload as a deployed C-address or, if no corresponding contract exists, as a G-address and attempts to mint through the Stellar Asset Contract. A classic Stellar account identified by a G-address can receive and hold an issued asset only through a trustline for that asset. Therefore, the recipient must have an authorized trustline whose remaining limit can accommodate the transferred amount. The Stellar OFT only invokes the mint operation and does not create a missing trustline, as trustline creation requires authorization from the recipient and sufficient XLM reserve. If these requirements are not satisfied, destination execution reverts after the source tokens have already been burned. The message remains retryable, but the tokens remain unavailable until the trustline is established or the intended contract is deployed and the message is retried.

RECOMMENDATION

Document that G-address recipients must exist and establish an authorized trustline for the Stellar asset before receiving an inbound transfer.

RESOLUTION

Status: Pending.

INFO I-02

PENDING

Quoted Maximum Ignores Dust Rounding.

CATEGORY Rounding LOCATION stellar-contracts/oft/src/oft.rs:L62-L80; stellar-contracts/oft/src/oft.rs:L93-L133

DESCRIPTION

The `quote_oft` function derives the maximum input from the available outbound rate limit capacity. When a fee is configured, the contract converts the available post-fee capacity into an estimated maximum pre-fee input, intending the result to represent the largest input accepted by `send`.

RUST

```
1      let mut max_amount_ld = Self::rate_limit_capacity(env, &Direction::Outbound, send_param.dst_eid);
2      if max_amount_ld != i128::MAX {
3          // Back-calculate pre-fee amount so max_amount_ld represents the largest input to send()
4          max_amount_ld = Self::__amount_before_fee(env, send_param.dst_eid, max_amount_ld);
5      } else {
6          // No rate limit configured – use the bounded default
7          max_amount_ld = u64::MAX as i128;
8      }
9      limit.max_amount_ld = max_amount_ld;
```

However, during execution, the contract rounds the amount down according to the decimal conversion rate before applying the rate limit.

RUST

```
1      let (amount_sent_ld, amount_received_ld) = if !has_fee {
2          // No fee: dust stays with sender (default OFT behavior)
3          let amount_sent_ld = oft_utils::remove_dust(amount_ld, conversion_rate);
4          (amount_sent_ld, amount_sent_ld)
5      } else {
6          // With fee: match EVM OFTFee behavior
7          // – sender pays full amount_ld (no dust removed), dust is absorbed into the charged fee
8          let fee = Self::__fee_view(env, dst_eid, amount_ld);
9          let amount_received_ld = oft_utils::remove_dust(amount_ld - fee, conversion_rate);
10         (amount_ld, amount_received_ld)
```

The rate limiter consequently checks the normalized `amount_received_ld`, rather than the original input. As a result, inputs above the reported maximum can still be accepted when fee calculation and dust removal round them down to an amount within the available capacity. Consequently, integrations relying on the quoted maximum may unnecessarily reject valid transfers.

RECOMMENDATION

Calculate `max_amount_ld` using the same fee and dust rounding as `send`, so it reflects the largest accepted input.

RESOLUTION

Status: Pending.

INFO I-03

PENDING

Unsafe Single-Step SAC Admin Transfer.

CATEGORY Best Practices LOCATION stellar-contracts/sac-manager/src/sac_manager.rs:L69-L72

DESCRIPTION

The SAC Manager allows an account holding `ADMIN_MANAGER_ROLE` to transfer SAC administration immediately to any supplied address. The new administrator is not validated and is not required to accept the transfer. After execution, the Manager loses SAC authority and cannot restore itself because any subsequent administrative transfer must be authorized by the new administrator. Consequently, transferring administration to an incorrect or nonfunctional address can permanently disable minting and other SAC administrative operations.

RECOMMENDATION

Implement a two-step transfer in which the current administrator proposes a new administrator and the proposed administrator authenticates an acceptance before the Manager calls the SAC's `set_admin`.

RESOLUTION

Status: Pending.

INFO **I-04**

PENDING

Stellar Pause Leaves Inbound Transfers Pending.

CATEGORY Documentation LOCATION stellar-contracts/oft/src/oft.rs:L93-L140

DESCRIPTION

The Stellar pause mechanism blocks both outgoing debits and incoming credits. Outgoing transfers are pause protected indirectly, as both `debit` implementations invoke `__debit_view` before locking or burning tokens, and that function checks the pause state. Incoming transfers are rejected directly by `__credit`. This creates a cross-chain asymmetry because the EVM OFT has no corresponding pause mechanism and cannot prevent transfers targeting a paused Stellar deployment. An EVM-to-Stellar transfer can burn tokens successfully on EVM, after which destination execution reverts when Stellar attempts to credit the recipient. Conversely, a Stellar-to-EVM transfer is rejected before any Stellar tokens are locked or burned. The failed inbound message remains retryable, so the tokens are not lost. However, they remain unavailable until Stellar is unpaused and the message is retried.

RECOMMENDATION

Document that pausing Stellar also suspends settlement of transfers already initiated from other EVM chains. Monitor failed inbound deliveries and establish a process to retry them after unpausing.

RESOLUTION

Status: Pending.

§ 05

Disclaimer.

This report is not, nor should be considered, an “endorsement” or “disapproval” of any particular project or team. This report is not, nor should be considered, an indication of the economics or value of any “product” or “asset” created by any team or project that contracts Guardian to perform a security assessment. This report does not provide any warranty or guarantee regarding the absolute bug-free nature of the technology analyzed, nor do they provide any indication of the technologies proprietors, business, business model or legal compliance.

This report should not be used in any way to make decisions around investment or involvement with any particular project. This report in no way provides investment advice, nor should be leveraged as investment advice of any sort. This report represents an extensive assessing process intending to help our customers increase the quality of their code while reducing the high level of risk presented by cryptographic tokens and blockchain technology.

Blockchain technology and cryptographic assets present a high level of ongoing risk. Guardian's position is that each company and individual are responsible for their own due diligence and continuous security. Guardian's goal is to help reduce the attack vectors and the high level of variance associated with utilizing new and consistently changing technologies, and in no way claims any guarantee of security or functionality of the technology we agree to analyze.

The assessment services provided by Guardian is subject to dependencies and under continuing development. You agree that your access and/or use, including but not limited to any services, reports, and materials, will be at your sole risk on an as-is, where-is, and as-available basis.

Cryptographic tokens are emergent technologies and carry with them high levels of technical risk and uncertainty. The assessment reports could include false positives, false negatives, and other unpredictable results. The services may access, and depend upon, multiple layers of third-parties.

Notice that smart contracts deployed on the blockchain are not resistant from internal/external exploit. Notice that active smart contract owner privileges constitute an elevated impact to any smart contract's safety and security. Therefore, Guardian does not guarantee the explicit security of the audited smart contract, regardless of the verdict.

About Guardian.

Founded in 2022 by DeFi experts, Guardian is a leading audit firm in the DeFi smart contract space. With every audit report, Guardian upholds best-in-class security while achieving our mission to relentlessly secure DeFi.